

Phishing Guidance Knowledge Base

A 50-item question-and-answer reference set for a phishing-focused Retrieval Augmented Generation system

This document contains a domain-specific cybersecurity knowledge base centered on phishing detection, phishing response, credential protection, and incident handling. Each entry is written as a practitioner-style question and answer, with a source tag mapped to an authoritative reference list. The structure is intentionally suited for chunking, embedding, retrieval, and downstream RAG evaluation.

1. How can staff recognize phishing emails?

Answer: Look for urgent requests, strange domains, unexpected attachments, and requests for passwords or payment details. Verify using a separate trusted channel.

Reference: R1 - FTC - How to Recognize and Avoid Phishing Scams

2. What should a user do after clicking a phishing link?

Answer: Change relevant passwords immediately, enable MFA, run a device scan, and notify the security team so containment can begin quickly.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

3. What is spear phishing?

Answer: Spear phishing is a targeted phishing attempt tailored to a person, role, or organization using contextual details to look legitimate.

Reference: R5 - OWASP - Phishing and Spear Phishing Guidance

4. Why is urgency common in phishing messages?

Answer: Urgency reduces careful thinking and pushes users to act before verifying a sender, link, or attachment.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

5. How should employees handle suspicious attachments?

Answer: Do not open them. Report the message, quarantine if possible, and let security staff review the file safely.

Reference: R4 - CISA - Recognize and Report Phishing

6. Why is MFA useful against phishing?

Answer: MFA lowers the chance that stolen passwords alone will let attackers access accounts or move laterally.

Reference: R7 - Microsoft Security - MFA and Identity Protection Guidance

7. What technical controls reduce phishing exposure?

Answer: Use email filtering, secure gateways, SPF, DKIM, DMARC, and monitoring for unusual account behavior.

Reference: R8 - Cloudflare Learning Center - SPF, DKIM and DMARC

8. How should security teams triage a phishing report?

Answer: Identify who received the message, whether anyone clicked, which accounts may be affected, and which indicators need blocking.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

9. What is business email compromise?

Answer: It is fraud based on impersonating executives, finance staff, or vendors to trigger payments or disclosure of sensitive information.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

10. How can finance teams verify payment requests safely?

Answer: Use out-of-band verification such as a known phone number or established workflow before any transfer or account change.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

11. What signs suggest a fake login page?

Answer: Misspelled domains, poor branding, unusual URLs, and prompts for credentials after unexpected emails are strong warning signs.

Reference: R1 - FTC - How to Recognize and Avoid Phishing Scams

12. Why should users hover over links?

Answer: Hovering reveals the destination URL and helps detect mismatched or malicious domains before clicking.

Reference: R4 - CISA - Recognize and Report Phishing

13. What should happen if credentials were submitted to a fake site?

Answer: Reset the password, reset reused passwords on other services, enable MFA, and review recent account activity for abuse.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

14. How can organizations improve phishing reporting?

Answer: Provide a simple reporting button, reinforce it in training, and acknowledge reports so users keep participating.

Reference: R4 - CISA - Recognize and Report Phishing

15. Why are phishing simulations used?

Answer: They help measure awareness, identify weak points, and support targeted coaching without waiting for real incidents.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

16. What is a lookalike domain?

Answer: A lookalike domain imitates a trusted brand using similar spelling, extra words, or visually similar characters.

Reference: R1 - FTC - How to Recognize and Avoid Phishing Scams

17. How should help desks respond to a phishing incident?

Answer: Verify identity carefully, prioritize account protection, log the ticket, and coordinate with security for containment and evidence retention.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

18. What role do SPF, DKIM, and DMARC play?

Answer: They help verify sender authenticity, reduce spoofing, and improve domain-based protection against fraudulent emails.

Reference: R8 - Cloudflare Learning Center - SPF, DKIM and DMARC

19. Why should organizations maintain an incident response plan?

Answer: A defined plan speeds containment, clarifies responsibilities, and reduces confusion during active phishing incidents.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

20. What is the first priority after a phishing compromise?

Answer: Protect accounts and systems at risk by resetting credentials, revoking sessions, and containing any affected endpoints.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

21. How can remote workers reduce phishing risk?

Answer: Use MFA, company-approved communication channels, device updates, and verification procedures for urgent requests.

Reference: R7 - Microsoft Security - MFA and Identity Protection Guidance

22. Why do attackers impersonate trusted brands?

Answer: Trust reduces suspicion and increases the chance users will click links, open files, or disclose credentials.

Reference: R1 - FTC - How to Recognize and Avoid Phishing Scams

23. What should users do with suspicious SMS messages?

Answer: Do not tap links, do not reply, verify independently, and report the message through the approved process.

Reference: R4 - CISA - Recognize and Report Phishing

24. How can phishing lead to malware infection?

Answer: Links may direct users to malicious downloads or attachments may execute scripts that install malware on the device.

Reference: R4 - CISA - Recognize and Report Phishing

25. What logging is useful after phishing incidents?

Answer: Keep authentication logs, message samples, timestamps, recipient lists, clicked URLs, and response actions for investigation.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

26. How should organizations protect high-risk roles?

Answer: Executives, finance staff, and admins should receive extra training, strong MFA, stricter approval workflows, and closer monitoring.

Reference: R3 - NIST SP 800-53 Rev. 5 - Security and Privacy Controls

27. Why is password reuse dangerous in phishing?

Answer: A single stolen password can expose multiple systems and make compromise much wider than one account.

Reference: R7 - Microsoft Security - MFA and Identity Protection Guidance

28. How can security awareness training be more effective?

Answer: Use short recurring lessons, realistic examples, feedback after simulations, and role-specific scenarios.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

29. What is credential harvesting?

Answer: It is the collection of usernames, passwords, or codes through deceptive forms or messages.

Reference: R5 - OWASP - Phishing and Spear Phishing Guidance

30. How can users verify a sender safely?

Answer: Use a known contact path, official website, or approved directory instead of replying directly to the suspicious message.

Reference: R1 - FTC - How to Recognize and Avoid Phishing Scams

31. What should happen to confirmed malicious domains?

Answer: They should be blocked in mail and web controls, added to detection systems, and shared internally where appropriate.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

32. How can mailbox rules be abused after phishing?

Answer: Attackers may create hidden forwarding or deletion rules to conceal alerts and maintain persistence in the victim mailbox.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

33. What should administrators check after account takeover?

Answer: Review sign-in history, MFA changes, mail rules, delegated access, tokens, and suspicious administrative actions.

Reference: R7 - Microsoft Security - MFA and Identity Protection Guidance

34. Why is transparency important in phishing guidance?

Answer: Clear actions, clear sources, and clear escalation paths improve trust and reduce hesitation during incidents.

Reference: R4 - CISA - Recognize and Report Phishing

35. How should small organizations handle phishing with limited resources?

Answer: Focus on MFA, simple reporting, staff awareness, patching, backups, and a lightweight incident response checklist.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

36. What is a safe response to an unexpected invoice email?

Answer: Do not pay immediately. Verify the sender and invoice details through an established business contact route.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

37. How can phishing target cloud services?

Answer: Attackers imitate single sign-on or cloud storage alerts to steal credentials and access shared data.

Reference: R7 - Microsoft Security - MFA and Identity Protection Guidance

38. What controls help detect suspicious logins after phishing?

Answer: Use conditional access, anomaly detection, impossible travel alerts, and rapid credential revocation workflows.

Reference: R7 - Microsoft Security - MFA and Identity Protection Guidance

39. Why should suspicious messages be preserved?

Answer: Preserving them supports investigation, helps identify indicators, and improves later awareness training.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

40. How can organizations measure phishing resilience?

Answer: Track report rate, click rate, repeat failures, time to report, and response quality across simulations or real incidents.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

41. What is social engineering?

Answer: It is the manipulation of people into taking unsafe actions or revealing information by exploiting trust, fear, or routine.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

42. How should teams communicate during a phishing incident?

Answer: Use approved internal channels, assign roles, share verified facts, and avoid rumor-driven decisions.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

43. Why is patching still relevant to phishing defense?

Answer: Phishing may lead to malware execution, so reducing exploitable software weaknesses limits impact after a click.

Reference: R3 - NIST SP 800-53 Rev. 5 - Security and Privacy Controls

44. How can backups reduce phishing impact?

Answer: Backups support recovery if phishing leads to ransomware or destructive malware events.

Reference: R3 - NIST SP 800-53 Rev. 5 - Security and Privacy Controls

45. What makes phishing guidance actionable?

Answer: Actionable guidance tells practitioners exactly what to check, what to stop, who to notify, and what to document.

Reference: R4 - CISA - Recognize and Report Phishing

46. How can organizations avoid over-relying on technical controls?

Answer: Combine tools with people-focused processes such as awareness, verification culture, and rehearsed incident response.

Reference: R6 - CISA - Avoiding Social Engineering and Phishing Attacks

47. Why is role-based guidance useful?

Answer: Different roles face different risks, so tailored instructions are more relevant and more likely to be followed.

Reference: R3 - NIST SP 800-53 Rev. 5 - Security and Privacy Controls

48. How should organizations review phishing lessons learned?

Answer: Document what happened, where controls failed, what worked well, and how training or procedures should change.

Reference: R2 - NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

49. What should employees never share by email without verification?

Answer: Passwords, MFA codes, payment changes, confidential files, and identity documents should never be sent without independent verification.

Reference: R1 - FTC - How to Recognize and Avoid Phishing Scams

50. How can a practitioner respond to repeated phishing against one team?

Answer: Increase targeted training, tighten filtering, review approval workflows, and monitor the group more closely for follow-on compromise.

Reference: R3 - NIST SP 800-53 Rev. 5 - Security and Privacy Controls

Reference Map

R1: FTC - How to Recognize and Avoid Phishing Scams

R2: NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide

R3: NIST SP 800-53 Rev. 5 - Security and Privacy Controls

R4: CISA - Recognize and Report Phishing

R5: OWASP - Phishing and Spear Phishing Guidance

R6: CISA - Avoiding Social Engineering and Phishing Attacks

R7: Microsoft Security - MFA and Identity Protection Guidance

R8: Cloudflare Learning Center - SPF, DKIM and DMARC